

Mini Web VAPT Assessment — Day 29

1. Executive Summary

A scoped vulnerability assessment was performed against an intentionally vulnerable web application in an authorized laboratory environment.

The assessment covered reconnaissance, service enumeration, endpoint discovery, automated scanning, and manual security testing.

2. Objective

- Identify exposed web services
- Discover application endpoints
- Perform basic vulnerability scanning
- Conduct at least two manual security tests
- Document evidence and remediation recommendations

3. Scope

Item	Details
Target IP	TARGET_IP
Target URL	TARGET_URL
Environment	Authorized local laboratory
Application	DVWA

4. Methodology

1. Reconnaissance
2. Nmap service enumeration
3. Burp Suite HTTP inspection
4. FFUF endpoint discovery
5. Nikto/Nuclei scanning
6. Manual vulnerability testing
7. Evidence collection
8. Risk analysis and remediation

5. Tools Used

- Nmap
- Burp Suite
- FFUF
- Nikto
- Nuclei
- cURL

6. Reconnaissance Results

Document the target, HTTP service, server information, and discovered ports.

7. Endpoint Discovery

Document significant endpoints discovered using FFUF and manual browsing.

8. Automated Scanning

Nmap

Summarize relevant open ports and services.

Nikto

Summarize relevant findings.

Nuclei

Summarize relevant findings, if available.

9. Manual Testing

VAPT-01 — SQL Injection

Document: - Endpoint - Parameter - Test input - Observed behavior - Security impact - Evidence - Remediation

VAPT-02 — Reflected XSS

Document: - Endpoint - Parameter - Test payload - Observed behavior - Security impact - Evidence - Remediation

10. Findings Summary

ID	Finding	Severity	Evidence
VAPT-01	SQL Injection	TBD	06-manual-test-01.png
VAPT-02	Reflected XSS	TBD	07-manual-test-02.png

11. Remediation

Provide practical recommendations for each confirmed finding.

12. Conclusion

The assessment demonstrated the use of reconnaissance, endpoint discovery, automated scanning, and manual web application security testing against an intentionally vulnerable application in an authorized laboratory environment.